

Splunk 2: Série Blue Primer - Boss of the SOC (BOTS) v2

Briefing do Cenário: Investigação Frothly

Esta sala faz parte da série Blue Primer e é baseada na versão 2 da competição *Boss of the SOC (BOTS)* da Splunk.

Neste cenário inicial, assumo a persona de Alice Bluebird, a analista que auxiliou com sucesso a Wayne Enterprises e que agora foi recomendada a Grace Hoppy na Frothly (uma empresa de cerveja) para ajudá-los a investigar seus problemas recentes de segurança.

O foco inicial desta investigação é responder a uma pergunta estrutural básica: **Que tipos de eventos temos disponíveis?**

Contexto Técnico Apresentado (Reconhecimento)

A plataforma apresenta a metodologia para mapear os eventos utilizando os metadados da linguagem de processamento de pesquisa (SPL) do Splunk. O comando `metadata` foi demonstrado como uma ferramenta útil para buscar informações equivalentes ao "Resumo de Dados" nativo, com a vantagem de permitir pesquisas direcionadas a um índice específico.

Também foi introduzido que, como os valores de tempo retornados por padrão estão no formato de máquina (EPOCH), é necessário aplicar o comando `eval` para converter e formatar essas datas de forma amigável para o analista.

Estrutura da Consulta Base

Foi fornecido o seguinte exemplo de comando para pesquisar o índice `botstv2`, retornando a lista de tipos de origem (*sourcetypes*), a contagem total de eventos e as datas de primeira e última visualização:

Snippet de código

- | metadata type=sourcetypes index=botstv2
- | eval firstTime=strftime(firstTime,"%Y-%m-%d %H:%M:%S")
- | eval lastTime=strftime(lastTime,"%Y-%m-%d %H:%M:%S")
- | eval recentTime=strftime(recentTime,"%Y-%m-%d %H:%M:%S")
- | sort - totalCount

Nota: Esta base estrutural provém do aplicativo "APTs de Caça Avançada com Splunk".

O que foi realizado

- **O que foi feito durante a atividade:** Realizei a leitura do briefing inicial e o reconhecimento do cenário da Frothly. Analisei a estrutura da query base fornecida pela plataforma para o mapeamento inicial de logs.
- **Os principais conceitos aprendidos:** A teoria por trás do uso do comando `metadata` na linguagem SPL (Search Processing Language) para obter resumos de fontes de dados e a necessidade de conversão de tempo (formato EPOCH) utilizando a função `eval`.
- **Por que eles são importantes:** Entender o contexto do incidente e ter ferramentas para extrair metadados é o passo fundamental para compreender a visibilidade do ambiente. Isso dita como as futuras buscas investigativas serão planejadas.
- **Relevância de conceitos de segurança (Splunk/Logs):** O uso adequado do SPL para mapear *sourcetypes* é o que permite a um analista de SOC (Security Operations Center) entender rapidamente o volume e a natureza da telemetria disponível antes de iniciar a triagem de um incidente real.

Investigação Frothly: Rastreo de Comunicação com Concorrente

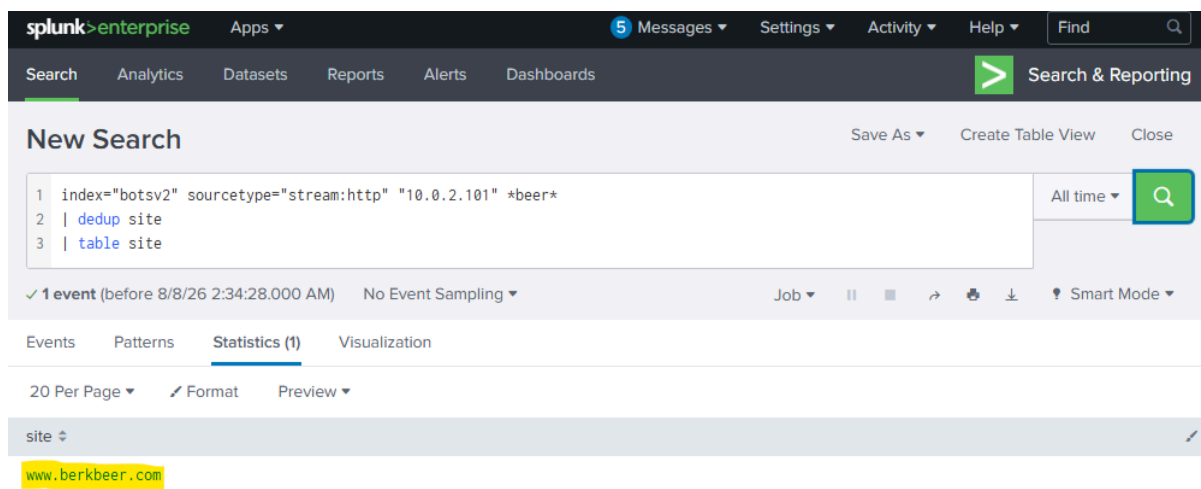
Resumo do Cenário

Nesta fase da investigação (baseada no conjunto de dados BOTSV2), o foco é a usuária Amber Turing. O objetivo é rastrear suas comunicações recentes e mapear suas interações com o site de uma empresa concorrente no mesmo setor.

Passo a Passo da Investigação

1. Identificação do IP da Usuária Comecei buscando o termo genérico `amber` no índice `botstv2`. Para isolar rapidamente o endereço IP dela, direcionei a busca especificamente para os logs de tráfego PAN (Firewall). Comando: `index="botstv2" sourcetype="pan:traffic"`

2. Descoberta do Site Concorrente (HTTP) Com o IP isolado, filtrei as requisições de tráfego web (`stream:HTTP`). Para limpar o volume de eventos, usei o setor da indústria cercado por asteriscos como filtro e comandos estruturais (representados por `KEYWORD`) para remover entradas duplicadas e formatar os domínios em tabela.



Comando: `index="botsv2" sourcetype="stream:http" "10.0.2.101" *beer*`

`| dedup site`

`| table site`

3. Mapeamento de Contatos da Diretoria Com o site identificado, restrinji a busca para analisar apenas o tráfego HTTP da Amber para esse domínio concorrente. Isso revelou o arquivo de imagem específico que exibia as informações de contato do executivo.

Comando: `index="botsv2" sourcetype="stream:http" "10.0.2.101" "www.berkbeer.com"`

4. Análise de Tráfego de E-mail (SMTP) e Decodificação

Pela imagem, descobri o sobrenome do CEO, mas precisava do nome completo e das evidências da conversa. Para investigar o tráfego SMTP, primeiro localizei o endereço de e-mail corporativo da Amber. Com essa informação em mãos, criei uma consulta focada no e-mail dela e no domínio do concorrente para isolar os eventos de comunicação.

Comando: `index="botsv2" sourcetype="stream:smtp" aturing@froth.ly "www.berkbeer.com"`

Evidências Extraídas (Questões Essenciais)

A partir da correlação estruturada acima, localizei nos logs as respostas para os seguintes pontos do incidente:

- Domínio exato visitado por Amber para encontrar a equipe executiva.
- Caminho do arquivo de imagem com o contato do executivo.
- Nome e sobrenome do CEO concorrente.
- Endereço de e-mail do CEO.

- Endereço de e-mail de outro funcionário contatado por ela na concorrente.
- Nome do arquivo anexo enviado para o contato na empresa concorrente.
- Endereço de e-mail pessoal da Amber (descoberto ao final da análise de comunicações).

O que foi realizado

- **O que foi feito:** Rastreei as atividades de uma usuária específica, cruzando o isolamento de IP, o mapeamento de tráfego web direcionado à concorrência e a análise das comunicações por e-mail (SMTP).
- **Principais conceitos aprendidos:** O uso do método de funil em consultas de busca (começar com termos genéricos e restringir por campos específicos como `site` ou `INDUSTRY`) para focar nos eventos relevantes.
- **Por que é importante:** A habilidade de correlacionar eventos distintos — como visitar um site e, em seguida, estabelecer comunicação por e-mail com o mesmo domínio — é o que permite montar a linha do tempo do incidente.
- **Relevância em SIEM/Logs:** A atividade demonstra a utilidade da centralização de logs em ferramentas de SIEM. Alternar entre diferentes tipos de origem (*sourcetypes*), como `pan:traffic`, `stream:HTTP` e `stream:smtp`, permitiu investigar a atividade em múltiplas camadas usando uma única consulta progressiva.

Splunk Blue Primer: Série Blue Primer - Boss of the SOC (BOTS) v2 (Série 200)

Resumo da Investigação

Nesta etapa, o objetivo foi resolver a série de perguntas 200 do conjunto de dados BOTSv2. A investigação exigiu a construção de diversas consultas no Splunk para rastrear desde a instalação de softwares de anonimato até a identificação de ataques diretos contra a infraestrutura web da Frothly, incluindo explorações de SQL, XSS e spear phishing.

Como mencionado na própria plataforma, a abordagem descrita durante a tarefa é apenas um guia e não a única maneira de realizar essas consultas no Splunk.

Passo a Passo da Investigação

1. Rastreamento de Instalação do Tor

A primeira tarefa foi identificar a versão exata do navegador Tor que a usuária Amber instalou. Iniciei a investigação com uma busca básica por palavras-chave focada na usuária e no software:

Snippet de código

- `index="botsv2" amber tor`

Essa consulta retornou mais de 300 resultados. Para isolar o evento exato da instalação, precisei adicionar uma terceira palavra-chave (representada por **KEYWORD**) à consulta para restringir os eventos e encontrar a resposta.

2. Mapeamento de Escaneamento de Vulnerabilidades

O próximo passo exigiu determinar dois endereços IP cruciais: o IPv4 público do site **brewertalk.com** e o endereço IP de origem que estava realizando uma varredura de vulnerabilidades na web contra ele. Utilizei as lógicas das consultas anteriores como guia para isolar esses endereços nos logs.

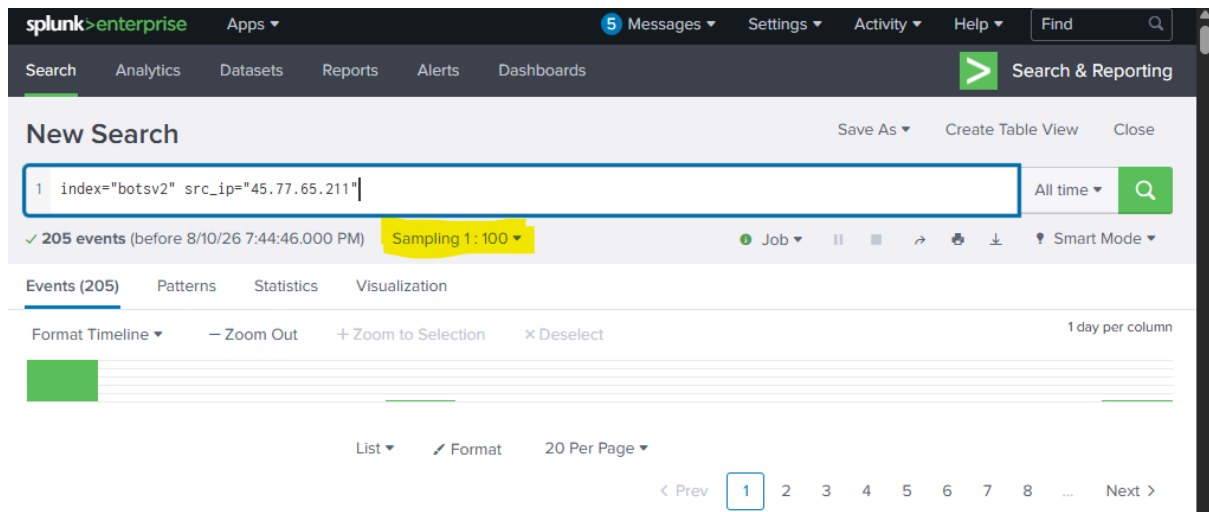
3. Análise de Ataque SQL

Com o endereço IP do atacante em mãos, construí uma nova consulta usando-o como IP de origem (**src_ip**):

Snippet de código

- `index="botsv2" src_ip="ATTACKER_IP"`

Nota Operacional Importante: Nesta consulta, foi necessário alterar a amostragem (*sampling*) para **1:100**. Caso contrário, a consulta seria cancelada automaticamente pelo sistema devido ao alto volume de dados (mais de 18.000 eventos retornados) e geraria erros.



Para refinar a busca, utilizei os "Campos Interessantes" (*Interesting Fields*) do Splunk para identificar qual caminho da URI estava sendo atacado. Após identificar o caminho, expandir a consulta para descobrir qual função SQL estava sendo usada indevidamente:

Snippet de código

- `index="botsv2" src_ip="ATTACKER_IP" uri_path="URI_PATH"`

Isso reduziu o escopo para cerca de 600 eventos, permitindo localizar a resposta exata.

4. Investigação de XSS e Spear Phishing

A última fase focou em um ataque de XSS envolvendo um novo usuário chamado Kevin. Para descobrir seu nome completo, iniciei com:

Snippet de código

- `index="botsv2" kevin`

Sabendo que o ataque ocorreu no tráfego HTTP, foquei em localizar um payload de XSS e o valor do cookie que o navegador de Kevin transmitiu para a URL maliciosa. Por fim, utilizando mais uma busca por palavra-chave (`index="botsv2" KEYWORD`), consegui identificar o nome de usuário do brewertalk.com que foi criado maliciosamente por meio de um ataque de spear phishing.

Evidências Extraídas (Questões Essenciais)

Abaixo estão as principais respostas extraídas dos logs durante esta fase da investigação:

- **Pergunta:** Qual versão do navegador Tor Amber instalou para ocultar sua navegação na web?
 - **Resposta:** 7.0.4
 - **Explicação:** Obtida filtrando os eventos da usuária "amber" com a palavra-chave "tor" e um termo adicional para isolar o evento de instalação.
- **Pergunta:** Forneça o endereço IP do sistema usado para executar uma varredura de vulnerabilidades da web no site www.brewertalk.com.
 - **Resposta:** 45.77.65.211
- **Pergunta:** O endereço IP da questão anterior também está sendo usado por um software para atacar um caminho URI. Qual função SQL está sendo usada indevidamente neste caminho URI?
 - **Resposta:** updatexml
 - **Explicação:** Encontrada isolando o **src_ip** do atacante (com amostragem de 1:100) e filtrando o campo **uri_path**.

< Hide Fields All Fields		Reports Top values Top values by time Rare values Events with this field	
SELECTED FIELDS a form_data 100+ a host 1 a source 2 a sourcetype 1		Top 10 Values Count %	
INTERESTING FIELDS # bytes 41 # bytes_in 30 # bytes_out 20 a dest_ip 1 a dest_mac 1 # dest_port 1 a endtime 100+ a flow_id 100+ a http_comment 2 # http_content_length 17 a http_content_type 1 a http_method 1 a http_user_agent 2 a index 1 # linecount 1 a protocol_stack 1 a punct 4 a server 1 a set_cookie[] 100+ a site 1 a splunk_server 1 a src_ip 1 a src_mac 1		quick_password=1n73rn37&url=1&submit=Login&action=do_login&quick_remember=yes&quick_login=1&quick_username=admin 2 0.302% quick_password=1nt3rn3t&url=1&submit=Login&action=do_login&quick_remember=yes&quick_login=1&quick_username=admin 2 0.302% quick_password=4dm1n&url=1&submit=Login&action=do_login&quick_remember=yes&quick_login=1&quick_username=admin 2 0.302% quick_password=admin&url=1&submit=Login&action=do_login&quick_remember=yes&quick_login=1&quick_username=admin 2 0.302% regcheck1=®check2=true&username=makman&password=mukarram&password2=mukarram&email=mak@live.com&email2=mak@live.com&referrername=&imagestring=F7yR4&imagehash=1c1d0e6eae9c113f4ff65339e4b3079c&answer=4&allownotices=1&receivepms=1&pmnotice=1&subscriptionmethod=0&timezoneoffset=0&dstcorrection=2®time=1416039333&step=registration&action=do_register®submit=SubmitRegistration!&question_id=makman' and updatexml(NULL,concat (0x3a,(LENGTH((SELECT email FROM mybb_users ORDER BY UID LIMIT 0,1))))),NULL) and '1	

- **Pergunta:** Qual era o valor do cookie que o navegador de Kevin transmitiu para a URL maliciosa como parte de um ataque XSS?
 - **Resposta:** 1502408189

O que foi realizado

- **O que foi feito durante a atividade:** Realizei a progressão de uma investigação de segurança analisando logs no Splunk. Identifiquei a instalação de software evasivo (Tor), mapeei o IP de um atacante realizando escaneamento de vulnerabilidades

web e rastreei a exploração subsequente desse ataque, que envolveu injeção de função SQL, roubo de cookies via XSS e criação de contas via spear phishing.

- **Os principais conceitos aprendidos:** O uso progressivo de palavras-chave no Splunk para afunilar resultados; a importância do ajuste de **amostragem (1:100)** para evitar o travamento ou cancelamento automático de consultas com alto volume de retorno; e a correlação entre campos específicos (como `src_ip` e `uri_path`).
- **Por que eles são importantes:** O domínio dessas técnicas de busca em logs é essencial para lidar com grandes conjuntos de dados (big data). Saber como otimizar uma consulta usando amostragem ou cruzamento de campos de tráfego HTTP evita a perda de tempo computacional e permite ao analista identificar rapidamente o vetor de ataque (SQL, XSS) e seu respectivo impacto (roubo de credenciais ou cookies).

Série Blue Primer - Boss of the SOC (BOTS) v2 (Série 300)

Resumo da Investigação

Nesta etapa da série 300 do conjunto de dados BOTSv2, o foco da investigação é uma usuária chamada Mallory, seu MacBook pessoal (nomeado *kutekitten*) e um incidente envolvendo arquivos criptografados por ransomware. A análise também engloba a identificação do vetor de infecção inicial: um pen drive malicioso inserido por outro usuário (Kevin), mapeado através dos logs do Osquery, além do rastreamento da comunicação do malware com servidores de Comando e Controle (C&C).

Passo a Passo da Investigação

1. Identificando o Dispositivo e o Arquivo Crítico

A investigação começou com o objetivo de localizar uma apresentação crítica em PowerPoint que havia sido criptografada. Primeiro, realizei uma busca por palavra-chave para encontrar eventos associados à usuária:

Snippet de código

```
index="botsv2" mallory
```

Ao observar os "Campos Seleccionados" nos mais de 11.000 eventos retornados, identifiquei o nome do MacBook de Mallory. Sabendo que uma busca apenas pelo nome do host retornaria mais de 9 milhões de eventos, adicionei extensões de arquivo comuns do PowerPoint para filtrar o documento exato:

Snippet de código

```
index="botsv2" host="NAME_MACBOOK" (*.ppt OR *.pptx)
```

Isso reduziu significativamente os resultados e revelou o nome do arquivo da apresentação importante.

The screenshot shows the Splunk Enterprise web interface. At the top, there's a navigation bar with 'Search' highlighted. Below it, a 'New Search' panel contains the search query: `1 index="botsv2" host="maclore-air13" (*.ppt OR *.pptx)`. The results show 7 events. The first event is expanded, showing a file path: `BKRDmukR/Volumes//FROTHLY/Home/mallory.krausen/Frothly_marketing_campaign_Q317.pptx.crypt/Volumes//FROTHLY/Home/mallory.krausen/Frothly_marketing_campaign_Q317.pptx`. The second event shows a file path: `host = MACLORE-AIR13 | source = ps | sourcetype = ps`. The interface includes various controls like 'Format Timeline', 'Zoom Out', 'Zoom to Selection', and 'Deselect'.

2. Localizando Outros Arquivos Criptografados (Vídeo)

O próximo passo foi encontrar um arquivo de vídeo (um episódio de *Game of Thrones*) que também foi alvo do ransomware. Como a extensão original do vídeo era desconhecida, utilizei o mesmo tipo de origem (*sourcetype*) da consulta anterior, mas foquei na extensão que o arquivo ganha **depois** de ser criptografado:

Snippet de código

```
index="botsv2" host="NAME_MACBOOK" sourcetype="?" *.EXT
```

(Nota: O `?` foi substituído pelo *sourcetype* identificado no passo 1 e `.EXT` pela extensão maliciosa). A resposta foi encontrada na primeira página dos resultados.

3. Análise da Infecção via USB usando Osquery

A infecção ocorreu após Kevin inserir um pen drive no MacBook pessoal de Mallory (*kutekitten*). Para investigar isso, utilizei os logs gerados pelo **Osquery** — uma ferramenta que expõe o sistema operacional como um banco de dados relacional de alto desempenho, permitindo usar SQL para explorar dados do sistema, como processos, rede e eventos de hardware.

Iniciei buscando o nome do host e mapeando a estrutura de pastas do usuário:

Snippet de código

```
index="botstv2" kutekitten "\\PATH\\MALLORY\\FOLDER"
```

(Nota: O caminho precisou ser escapado duas vezes com `\\` para que a consulta fosse executada com sucesso).

Ao analisar os campos interessantes, procurei por um arquivo anômalo cujo campo mostrasse uma contagem de 1. Confirmei o hash desse arquivo no **VirusTotal**.

4. Correlação Temporal e Fabricante do USB

Para encontrar o fabricante do pen drive, mudei o foco para eventos ocorridos exatamente **1 minuto antes** da execução do malware, clicando na data/hora do evento para visualizar a janela de tempo adjacente.

Snippet de código

```
index="botstv2" kutekitten KEYWORD KEYWORD
```

Evidências Extraídas (Questões Essenciais)

A partir da correlação e das buscas documentadas acima, localizei nos logs as respostas para os seguintes pontos críticos do incidente:

- **Pergunta:** A apresentação crucial de Mallory em PowerPoint, armazenada em seu MacBook, foi criptografada por um ransomware em 18 de agosto. Qual é o nome desse arquivo após a criptografia?
 - **Resposta:** Frothly_marketing_campaign_Q317.pptx.crypt
- **Pergunta:** Kevin Lagerfield usou um pen drive para transferir malware para o Kutekitten. Forneça o nome do fabricante do pen drive que Kevin provavelmente usou.
 - **Resposta:** Alcor Micro Corp. (vendedor id 058f)
 - **Explicação:** Encontrado isolando o evento do malware, ajustando a busca para 1 minuto antes e analisando os logs de eventos de hardware do Osquery.
- **Pergunta:** Quando esse malware foi detectado pela primeira vez em atividade?
 - **Resposta:** 2017-01-17

- **Pergunta:** O malware que infecta o Kutekitten usa destinos DNS dinâmicos para se comunicar com dois servidores de comando e controle (C&C) logo após a instalação. Qual é o nome de domínio totalmente qualificado (FQDN) do primeiro (em ordem alfabética) desses destinos?
 - **Resposta:** eidk.duckdns.org

O que foi realizado

- **O que foi feito durante a atividade:** Conduzi a investigação de um ataque de ransomware e malware, rastreando o vetor de infecção físico (um pen drive inserido em um MacBook). Identifiquei arquivos criptografados específicos, isolei o executável malicioso nas pastas do usuário, realizei correlação de tempo para mapear eventos de hardware e identifiquei domínios de Comando e Controle (C&C).
- **Os principais conceitos aprendidos:** O uso do **Osquery** integrado ao SIEM (Splunk) para analisar eventos profundos do sistema operacional (como conexões de hardware e processos) de forma relacional. Também aprendi a importância da sintaxe de escape (`\\`) na busca de caminhos de diretório e a técnica de **correlação temporal** (pivotar a busca para minutos anteriores a um evento anômalo para descobrir a causa raiz).
- **Por que eles são importantes:** Rastrear a origem exata de uma infecção é o pilar da Resposta a Incidentes. A habilidade de usar o SIEM não apenas para ver alertas de rede, mas para explorar logs de *endpoint* (via Osquery), permite validar o vetor físico (USB), confirmar a exfiltração ou ofuscação do malware e bloquear comunicações maliciosas (DNS dinâmico / C&C) para conter o ataque de forma efetiva.

Série Blue Primer - Boss of the SOC (BOTS) v2 (Série 400)

Resumo da Investigação

Nesta fase da investigação, avançamos para a série 400 de perguntas do conjunto de dados BOTSv2, focando em um agente de Ameaça Persistente Avançada (APT) conhecido como grupo **Taedonggang**. A análise englobou a identificação de um ataque de *spear phishing* contendo anexos protegidos por senha, a investigação de tráfego TCP criptografado para descobrir o Emissor SSL do atacante, a análise de malware com o auxílio de sandboxes externas e a descoberta de mecanismos de persistência utilizando tarefas agendadas para comunicação com servidores de Comando e Controle (C2).

Passo a Passo da Investigação

1. Rastreando o E-mail de Phishing e o Anexo

A investigação começou com a tarefa de descobrir o nome de um anexo malicioso enviado à Frothly pelo ator APT. Como isso envolvia eventos de e-mail, utilizei uma consulta focada no fluxo de dados (*stream*) e na extensão do arquivo. A sintaxe base utilizada foi:

Snippet de código

- `index="botstv2" sourcetype="stream:?" *.EXT`

(Nota: O `?` foi substituído pelo protocolo de e-mail adequado e `.EXT` pela extensão do arquivo comprimido). Através dessa mesma busca, investigando o conteúdo da mensagem e os campos associados, foi possível recuperar a senha utilizada para proteger o arquivo zip malicioso.

2. Investigação do Emissor SSL do Atacante

O grupo APT criptografa a maior parte do seu tráfego. Para identificar o Emissor SSL (*SSL Issuer*), utilizei o endereço IP do atacante (o mesmo que havia escaneado o site `brewertalk.com` em fases anteriores). Desta vez, direcionei a pesquisa para o fluxo TCP:

Snippet de código

- `index="botstv2" sourcetype="stream:?" ATTACKER_IP`

Ao analisar os resultados gerados, examinei a guia de "Campos Interessantes" (*Interesting Fields*) do Splunk, o que me permitiu extrair exatamente a string do emissor SSL utilizado nas comunicações do grupo Taedonggang.

3. Análise de Arquivos Incomuns e Transferência de Dados

A próxima etapa focou em investigar um arquivo incomum baixado junto com o binário `winsys32.dll`. Iniciei pesquisando o próprio binário:

Snippet de código

- `index="botstv2" winsys32.dll`

Os resultados revelaram uma ferramenta associada à transferência de arquivos entre sistemas. Usando o *sourcetype* associado a esse fluxo, refinei a busca para identificar comandos de download específicos, reduzindo a quantidade de eventos de mais de 1.000 para um número analisável:

Snippet de código

- `index="botstv2" sourcetype="stream:?" method=COMMAND`

Essa análise revelou o download de um arquivo com características incomuns para o contexto de uma empresa americana, indicando o uso de um idioma estrangeiro.

4. Análise de Malware via Sandboxes Externas

Para entender a execução completa do malware contido no arquivo zip inicial, apoiei a análise em plataformas de inteligência de ameaças externas baseadas nos links fornecidos:

- **Hybrid Analysis**
- **VirusTotal**
- **Any.run**

A análise dos relatórios de execução (*sandboxing*) forneceu acesso aos metadados do documento malicioso. Foi através desses relatórios que descobri o nome de uma pessoa inocente implicada na criação do arquivo que executou o *PowerShell Empire* na estação da vítima, além de detalhes específicos sobre o texto contido no documento isca.

5. Detecção de Persistência e C2 (Comando e Controle)

Para manter a persistência na rede da Frothly, o APT Taedonggang utilizou *Scheduled Tasks* (Tarefas Agendadas) no Windows para enviar *beacons* (sinais de retorno) ao seu servidor C2. Busquei pelas execuções do executável responsável:

Snippet de código

- `index="botsv2" schtasks.exe`

Ao analisar os mais de 100 eventos retornados, identifiquei anomalias e determinei as palavras-chave necessárias para mapear a página web específica que estava sendo mais acessada por essas tarefas agendadas de forma recorrente.

Evidências Extraídas (Questões Essenciais)

Abaixo estão as principais respostas consolidadas durante a investigação:

- **Pergunta:** Uma agência federal relata que o grupo Taedonggang frequentemente realiza ataques de phishing enviando arquivos compactados (zip) com senha. Qual o nome do anexo enviado ao Frothly por um agente malicioso do Taedonggang?
 - **Resposta:** invoice.zip
 - **Explicação:** Encontrado filtrando eventos de stream de rede relacionados a anexos compactados.
- **Pergunta:** Qual é a senha para abrir o arquivo zip?

- **Resposta:** 912345678

Time	Event
	<pre> oding: quoted-printable\r\n\r\n", "<html>\r\n<head>\r\n<meta http-equiv=3D\"Con tent-Type\" content=3D\"text/html; charset=3DUTF-8\">\r\n</head>\r\n<body>\r\n <div>\r\n<div data-node-type=3D\"line\" id=3D\"magicdomid2\">\r\n<div data-nod e-type=3D\"line\" id=3D\"magicdomid2\">\r\n<div data-node-type=3D\"line\" id=3 D\"magicdomid2\">As we have not received a =\r\nservice cessation letter, I am assuming that you might have accidentally =\r\noverlooked this invoice &lsquo; 02/160000506500 (Unpaid)&rsquo; for 10,000 =\r\nGBP. Should you wish to bring an end to the agreement please let us know. =\r\nOtherwise early withdrawal pe nalties will apply next month.&nbsp;</div>\r\n<div data-node-type=3D\"line\" i d=3D\"magicdomid3\">&nbsp;</div>\r\n<div data-node-type=3D\"line\" id=3D\"magi cdomid4\">Pleaser refer to the =\r\nattached document for payment details. Due to the personal nature of the =\r\naccount we have added a password to the doc ument. Please enter the =\r\npassword (912345678).</div>\r\n</div>\r\n</div>\r \r\n</div>\r\n<!--YMLPUF--><div align=3Dcenter style=3D\"padding-top:10px;paddin g-bottom:=\r\n10px;font-family:Verdana;font-size:8pt;color:#000000;\r\n\"><hr nosh ade =\r\ncolor=3D#000000 width=3D50% size=3D1>\r\nUnsubscribe / C hange Profile\r\n
\r\nPowered by =\r\nYMLP\r\n</div><!--YMLPUFE-->\r\n\r\n</body></html>\r\n\r\n--b1_de0c9808ea77d06 2a2ad3c3fa9b3b172\r\n\", \"Content-Type: application/octet-stream; name=\"invoic e.zip\">\r\nContent-Transfer-Encoding: base64\r\nContent-Disposition: attachmen t; filename=\"invoice.zip\">\r\n\r\n\", \"UESDBBQACQAI AE07AUvOniIRsz8AAACKAwALABwA </pre>

- **Pergunta:** O grupo APT Taedonggang criptografa a maior parte do seu tráfego com SSL. Qual é o "Emissor SSL" que eles usam para a maior parte do seu tráfego?
 - **Resposta:** C = US

- **Explicação:** Obtido filtrando o IP do atacante em fluxos TCP e verificando o campo de emissor nos metadados do SSL.

The screenshot shows a network analysis interface. At the top, a search bar contains the query: `1 index="botsv2" sourcetype="stream:tcp" 45.77.65.211`. Below the search bar, it indicates **29,069 events** (before 8/10/26 9:43:52.000 PM) with **No Event Sampling**. The interface has tabs for **Events (29,069)**, **Patterns**, **Statistics**, and **Visualization**. Below these tabs are controls for **Format Timeline**, **Zoom Out**, **Zoom to Selection**, and **Deselect**. A sidebar on the left shows **SELECTED FIELDS** (host, source, sourcetype, ssl_issuer) and **INTERESTING FIELDS** (ack_packets_in, ack_packets_out, app, bytes). The main panel displays a table of **ssl_issuer** values. The table has columns for **Values**, **Count**, and **%**. The data shows two values: **C = US** with a count of 14,189 (58.981%) and another value with a count of 9,868 (41.019%).

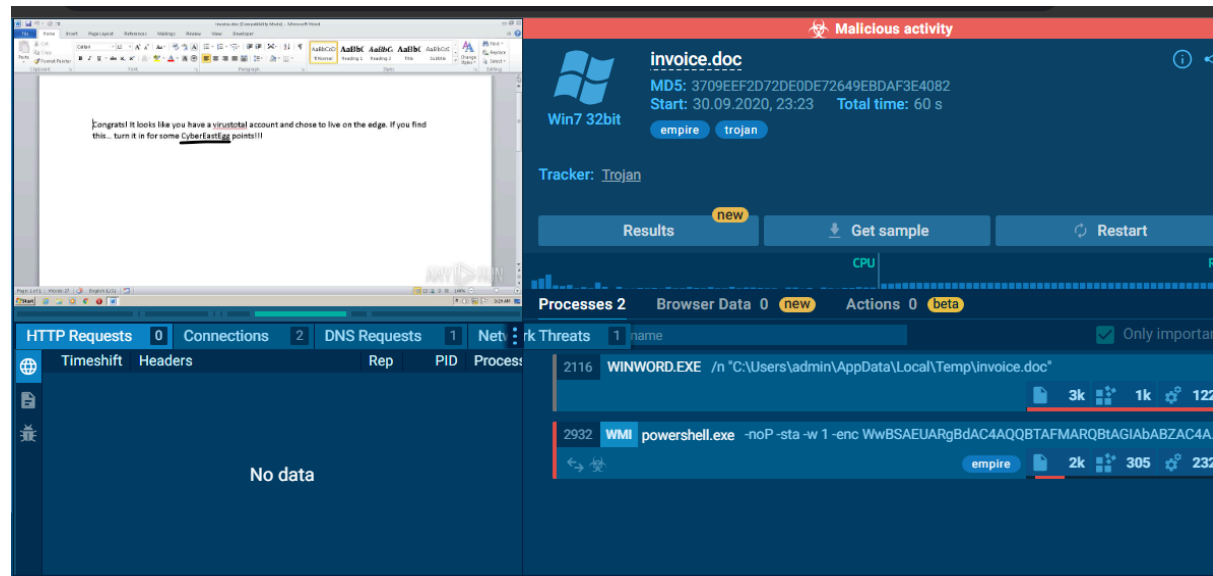
Values	Count	%
C = US	14,189	58.981%
	9,868	41.019%

- **Pergunta:** Qual é o nome e sobrenome do pobre coitado inocente que foi implicado nos metadados do arquivo que executou o PowerShell Empire na estação de trabalho da primeira vítima?
 - **Resposta:** Ryan Kovar

The screenshot shows the **File Details** page for a file named **invoice.doc**. The file is a **Composite Document File V2 Document** (Type: doc, office). The description includes metadata: **Author: Ryan Kovar**, **Template: Normal.dotm**, **Last Saved By: Ryan Kovar**, **Revision Number: 3**, **Name of Creating Application: Microsoft Macintosh Word**, **Total Editing Time: 01:00**, **Create Time/Date: Sun Jul 9 22:07:00 2017**, **Last Saved Time/Date: Wed Aug 2 05:26:00 2017**, **Number of Pages: 1**, **Number of Words: 21**, **Number of Characters: 125**, **Security: 0**. The **Architecture** is **WINDOWS** and the **SHA256** hash is **d8834aaa5ad6d8ee5ae71e042aca5cab960e73a6827e45339620359633608cf1**.

- **Pergunta:** No documento, que tipo de pontos são mencionados, caso você tenha encontrado o texto?

- **Resposta:** CyberEastEgg



- **Pergunta:** Para manter a persistência na rede Frothyly, o grupo APT configurou diversas Tarefas Agendadas para enviar sinais de retorno ao seu servidor de Comando e Controle (C2). Qual página da web é a mais acessada por essas Tarefas Agendadas?
 - **Resposta:** process.php
 - **Explicação:** Localizada investigando os processos do `schtasks.exe` associados à rede externa para identificar o *beacon* de C2.

O que foi realizado

- **O que foi feito durante a atividade:** Conduzi uma investigação aprofundada focada nas atividades de um grupo APT (Taedonggang). Analisei logs de e-mail em busca de vetores de *spear phishing*, investiguei fluxos de rede TCP para extrair indicadores SSL e rastreei comandos de transferência de arquivos em binários do sistema (`winsys32.dll`). Além da telemetria interna, consumi inteligência de fontes externas (VirusTotal, Any.run) para analisar o comportamento da ameaça em sandbox e finalizei rastreando a comunicação do malware com a infraestrutura do atacante (C2) por meio de tarefas agendadas.
- **Os principais conceitos e TTPs aprendidos:**
 - **Acesso Inicial (MITRE ATT&CK):** Uso de e-mails de *Spear Phishing* com Anexo protegido por senha para burlar varreduras de perímetro.
 - **Persistência (MITRE ATT&CK):** Abuso de *Scheduled Tasks* (`schtasks.exe`) para garantir a sobrevivência do malware após reinicializações.
 - **Comando e Controle - C2 (MITRE ATT&CK):** Comunicação de retorno criptografada via SSL e acesso a páginas web específicas para receber instruções do atacante.
 - **Execução:** Uso do *PowerShell Empire* para controle pós-exploração.
- **Por que eles são importantes:** Rastrear a "Kill Chain" de uma Ameaça Persistente Avançada exige a capacidade de cruzar dados de rede (SIEM/Splunk) com análise

comportamental de malware (sandboxing). Identificar IOCs cruciais, como um Emissor SSL específico de um grupo malicioso, permite a criação de regras globais de bloqueio, enquanto mapear a persistência (schtasks) garante que o ambiente seja devidamente higienizado na fase de resposta a incidentes.

Conclusão e Considerações Finais

A investigação do conjunto de dados **Boss of the SOC (BOTS) v2** proporcionou uma imersão técnica e realista no fluxo de trabalho de um analista de segurança (Blue Team / SOC) durante a resposta a um incidente complexo.

Ao longo das séries de perguntas, foi possível rastrear a cadeia completa de um ataque (Cyber Kill Chain), desde o reconhecimento e infecção inicial até a exfiltração de dados e persistência do atacante. O laboratório consolidou habilidades cruciais para a defesa cibernética, com destaque para:

- **Threat Hunting em SIEM:** Domínio na construção de consultas avançadas no **Splunk**, utilizando operadores booleanos, curingas, manipulação de amostragem (*sampling*) e correlação temporal para isolar eventos críticos em meio a milhões de logs ruidosos.
- **Análise Multicamadas:** A investigação não se limitou ao perímetro da rede. Houve o cruzamento de dados de tráfego web (HTTP/HTTPS), fluxos de rede brutos (TCP), e-mails (SMTP) e telemetria profunda de *endpoints* utilizando o **Osquery** para identificar artefatos físicos (USB) e anomalias de processos.
- **Mapeamento de TTPs (MITRE ATT&CK):** Identificação clara de táticas, técnicas e procedimentos avançados, como *Spear Phishing*, roubo de credenciais/cookies (XSS), Injeção de SQL, uso de *Scheduled Tasks* para persistência e comunicação criptografada com infraestruturas de Comando e Controle (C2).
- **Integração de Threat Intelligence:** A capacidade de pivotar os achados internos (hashes, domínios, IPs) para plataformas de inteligência e *sandboxing* externas (VirusTotal, Hybrid Analysis, Any.run) para compreender o comportamento de malwares ofuscados e APTs (como o grupo Taedonggang).

Em suma, esta documentação atesta a capacidade prática de conduzir a triagem (*triage*), investigação e contenção de ameaças em um ambiente corporativo, transformando dados brutos de telemetria em inteligência acionável para a mitigação de incidentes.

- Emissor SSL específico de um grupo malicioso, permite a criação de regras globais de bloqueio, enquanto mapear a persistência (**schtasks**) garante que o ambiente seja devidamente higienizado na fase de resposta a incidentes.